

Suricata NIDS Lab Report

Name: Ibrahim Khalid

Objective

To understand the implementation of a Network-based Intrusion Detection System (NIDS) using Suricata by deploying it on a Kali Linux virtual machine, configuring it to monitor live network traffic, and validating its detection capabilities through controlled reconnaissance and enumeration activity against a target host.

1. Lab Environment Setup

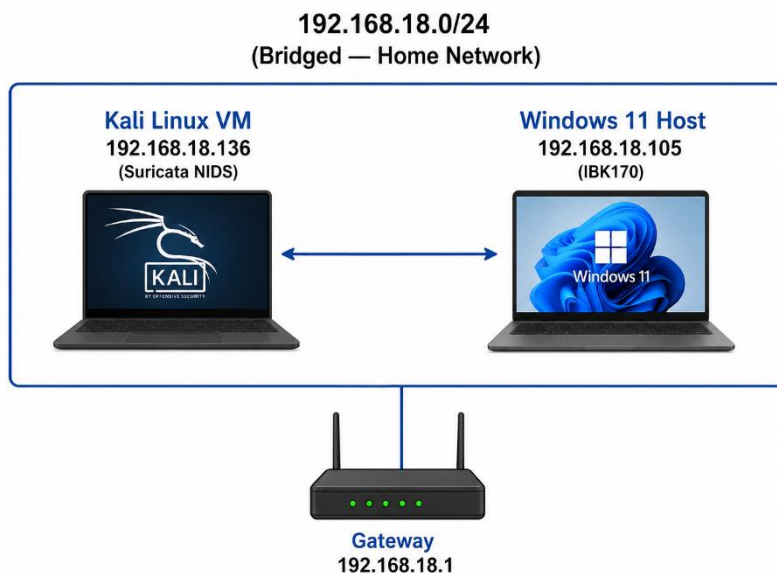
A virtualized lab was built using Oracle VirtualBox running on a Windows 11 host. The lab used a Bridged Adapter network configuration, which placed the Kali Linux VM directly on the same physical subnet as the Windows 11 host, allowing both machines to communicate as independent devices on the local network.

1.1 Network Topology

Role	Machine	IP Address	Network Mode
Attacker / NIDS Sensor	Kali Linux VM	192.168.18.136	Bridged Adapter
Target Host	Windows 11 (IBK170)	192.168.18.105	Physical NIC
Gateway	Home Router	192.168.18.1	—

Both machines resided on the 192.168.18.0/24 subnet. This topology was chosen so that Suricata, running on Kali, could observe genuine network traffic exchanged with a real target rather than synthetic NAT-only traffic, giving more realistic detection conditions.

1.2 Topology Diagram



2. Suricata Installation and Configuration

Suricata 8.0.5 was installed on Kali Linux and configured to monitor the bridged network interface (eth0). The Emerging Threats Open (ET Open) ruleset was enabled to provide signature-based detection in addition to Suricata's built-in protocol anomaly rules.

2.1 Installation Commands

```
sudo apt update && sudo apt install suricata -y
suricata --version

sudo suricata-update list-sources
sudo suricata-update enable-source et/open
sudo suricata-update
```

2.2 Configuration — suricata.yaml

The HOME_NET variable was set to match the lab subnet so Suricata correctly classified internal versus external traffic, and the capture interface was bound to the bridged adapter.

```
vars:
  address-groups:
    HOME_NET: "[192.168.18.0/24]"
    EXTERNAL_NET: "!$HOME_NET"

af-packet:
  - interface: eth0
    cluster-id: 99
    cluster-type: cluster_flow
    defrag: yes
```

2.3 Running Suricata

```
# Validate configuration
sudo suricata -T -c /etc/suricata/suricata.yaml -v

# Run in IDS (passive) mode on the bridged interface
sudo suricata -c /etc/suricata/suricata.yaml -i eth0

# Run as a persistent service
sudo systemctl enable suricata
sudo systemctl start suricata
```

Suricata started successfully in IDS mode under system mode with 8 worker threads, confirmed by the startup banner: "This is Suricata version 8.0.5 RELEASE running in SYSTEM mode" and "Threads created -> W: 8 FM: 1 FR: 1 Engine started."

2.4 Log Outputs

Log File	Purpose
/var/log/suricata/fast.log	Human-readable, one-line-per-alert summary
/var/log/suricata/eve.json	Structured JSON log of alerts, flows, DNS, and protocol events
/var/log/suricata/stats.log	Engine performance and capture statistics
/var/log/suricata/suricata.log	Engine startup, warnings, and errors

3. Configuration Troubleshooting

During setup, two issues were encountered and resolved. Documenting these is part of understanding how Suricata's rule engine validates and loads detection logic.

3.1 Issue — local.rules Not Loading

Suricata reported the following warning during configuration testing:

```
Warning: detect: No rule files match the pattern /var/lib/suricata/rules/local.rules
```

Cause: the custom rules file had been created under /etc/suricata/rules/ but Suricata's rule-files directive resolves relative paths against /var/lib/suricata/rules/ by default.

Fix:

```
sudo cp /etc/suricata/rules/local.rules /var/lib/suricata/rules/local.rules
sudo suricata -T -c /etc/suricata/suricata.yaml -v
```

3.2 Issue — SMB Rule Direction Warning

```
Warning: detect: rule 1000010: SYN-only to port(s) 445:445 w/o direction
specified, disabling for toclient direction
Warning: detect: rule 1000012: SYN-only to port(s) 445:445 w/o direction
specified, disabling for toclient direction
```

Cause: rules matching on the SYN flag alone were ambiguous about traffic direction, since SYN-flagged packets can theoretically appear in either direction during a TCP handshake.

Fix: an explicit flow:to_server; keyword was added to both rules, restricting the match to client-to-server SYN packets only, which resolved the ambiguity warning and matched the intended detection logic (a Kali source initiating connections to the Windows SMB port).

4. Reconnaissance and Enumeration Activity

With Suricata running and logging to fast.log, a series of reconnaissance techniques were executed from Kali against the Windows 11 target to generate real detection events and validate the sensor end-to-end.

4.1 Port Scanning — Nmap

```
nmap -sS 192.168.18.105 # SYN scan
nmap -sV 192.168.18.105 # Service/version detection
nmap -O 192.168.18.105 # OS fingerprinting
nmap -A 192.168.18.105 # Aggressive scan
nmap -p 3389 192.168.18.105 # RDP port check
nmap -p- --min-rate 5000 192.168.18.105 # Full 65535-port scan
```

Results — Open Ports Discovered:

Port	Service	Notes
135/tcp	msrpc	Microsoft RPC endpoint mapper
139/tcp	netbios-ssn	Legacy NetBIOS session service
445/tcp	microsoft-ds	SMB — primary attack surface
5040/tcp	unknown	Windows RPC (svchost-bound)
49664-49671/tcp	unknown	Dynamic RPC/DCOM endpoints
63527/tcp	unknown	Ephemeral high port
3389/tcp	ms-wbt-server	Closed — RDP disabled on target

4.2 SMB / NetBIOS Enumeration

```
enum4linux -a 192.168.18.105
nmap --script smb-enum-shares,smb-enum-users 192.168.18.105
nmap --script smb2-security-mode 192.168.18.105
nmap --script smb-vuln-ms17-010 192.168.18.105
```

enum4linux successfully identified the target's workgroup (WORKGROUP) and NetBIOS hostname (IBK170) via nbtstat, but a null SMB session was correctly rejected by the target: "Server doesn't allow session using username ", password ". Aborting remainder of tests." This confirmed the target was not vulnerable to anonymous SMB enumeration.

4.3 Credential Testing — CrackMapExec

```
crackmapexec smb 192.168.18.105 -u administrator -p /usr/share/wordlists/rockyou.txt
```

CrackMapExec fingerprinted the target as Windows 11 / Server 2025 Build 26100 x64 (hostname IBK170, domain ibk170) and reported SMB Signing: True and SMBv1: False. These two findings confirm the host is hardened against NTLM relay attacks (signing enabled) and EternalBlue-class exploits (SMBv1 disabled). The brute-force attempt subsequently timed out, consistent with Windows' built-in connection throttling against repeated authentication attempts.

4.4 Web Service Scanning

```
nikto -h http://192.168.18.105
dirb http://192.168.18.105
```

Both tools failed to connect, confirming port 80 was closed — no IIS or web service was running on the target.

5. Suricata Detection Results

Suricata logged the reconnaissance activity above to fast.log in real time. The following alert categories were generated during testing:

5.1 Alerts Captured

Signature ID	Alert Message	Trigger
2225005	SURICATA SMB malformed request dialects	enum4linux / nmap SMB scripts sending non-standard dialect negotiation
2100498	GPL ATTACK_RESPONSE id check returned root	curl test against testmynids.org validation endpoint
2051767	ET INFO DNS Query to Cloudflare Developer Domain	Side-effect DNS lookup from scanning tools
2051768	ET INFO Cloudflare Developer Domain in TLS SNI	Associated TLS connection to same CDN domain
2022973	ET INFO Possible Kali Linux hostname in DHCP Request	Kali's periodic DHCP lease renewal broadcasting its hostname

5.2 Sample Alert Output

```
06/30/2026-15:04:47.862186 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54244 → 192.168.18.105:445
06/30/2026-15:04:47.862696 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54244
06/30/2026-15:04:47.872693 [**] [1:1000014:1] LOCAL MSRPC Access Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:52536 → 192.168.18.105:135
06/30/2026-15:04:47.872982 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:135 → 192.168.18.136:52536
06/30/2026-15:04:47.863532 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54254 → 192.168.18.105:445
06/30/2026-15:04:47.863843 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54254
06/30/2026-15:04:47.910340 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54264 → 192.168.18.105:445
06/30/2026-15:04:47.912144 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54278 → 192.168.18.105:445
06/30/2026-15:04:47.912144 [**] [1:1000012:2] LOCAL SMB Brute Force Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54278 → 192.168.18.105:445
06/30/2026-15:04:47.912144 [**] [1:1000041:1] LOCAL SMB Auth Burst - Possible Brute Force [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54278 → 192.168.18.105:445
06/30/2026-15:04:47.912372 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54278
06/30/2026-15:04:47.910685 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54264
06/30/2026-15:04:49.973196 [**] [1:1000040:1] LOCAL Possible NTLM Auth Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54278 → 192.168.18.105:445
06/30/2026-15:04:50.807044 [**] [1:1000010:2] LOCAL SMB Enumeration Burst [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54280 → 192.168.18.105:445
06/30/2026-15:04:50.807044 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54280 → 192.168.18.105:445
06/30/2026-15:04:50.807343 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54280
06/30/2026-15:04:50.808232 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54290 → 192.168.18.105:445
06/30/2026-15:04:50.808455 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54290
06/30/2026-15:04:50.819607 [**] [1:1000014:1] LOCAL MSRPC Access Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:52550 → 192.168.18.105:135
06/30/2026-15:04:50.819908 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:135 → 192.168.18.136:52550
06/30/2026-15:04:50.858055 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54298 → 192.168.18.105:445
06/30/2026-15:04:50.858401 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54298
06/30/2026-15:04:50.859669 [**] [1:1000011:1] LOCAL SMB Access Attempt to IBK170 [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54308 → 192.168.18.105:445
06/30/2026-15:04:50.860077 [**] [1:1000020:1] LOCAL Dynamic RPC Port Access [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.105:445 → 192.168.18.136:54308
06/30/2026-15:04:52.777529 [**] [1:1000005:1] LOCAL ICMP Ping Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.18.1:8 → 192.168.18.136:0
06/30/2026-15:04:52.779744 [**] [1:1000005:1] LOCAL ICMP Ping Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.18.1:8 → 192.168.18.136:0
06/30/2026-15:04:52.922961 [**] [1:1000040:1] LOCAL Possible NTLM Auth Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.18.136:54308 → 192.168.18.105:445
```

5.3 Attack Timeline Reconstructed from Logs

Time	Event
13:46:13 – 13:46:16	Initial SMB enumeration burst (enum4linux)
13:46:35 – 13:46:37	DNS/TLS to Cloudflare CDN (web-scan side effect)
13:46:37 – 13:46:44	Burst of SMB connections — nmap smb-vuln* scripts
13:47:00 – 13:47:05	Second SMB connection wave
13:48:58 – 13:49:01	Third SMB connection wave — crackmapexec probe

The repeated SMB malformed dialect alerts, clustered into distinct time windows with multiple source ports, are a recognizable signature of automated enumeration tooling rather than normal user activity — exactly the kind of pattern a SOC analyst would triage as reconnaissance.

6. Custom Detection Rules

A local rule set was authored to detect the specific reconnaissance techniques used in this lab, supplementing the ET Open ruleset with detections tailored to the lab's observed attack surface (SMB, RPC, scanning behavior, and credential attacks).

6.1 Rule File Location

```
/var/lib/suricata/rules/local.rules

# Registered in suricata.yaml:
rule-files:
- suricata.rules
- local.rules
```

6.2 Reconnaissance Rules

```
alert tcp $HOME_NET any -> $HOME_NET any (msg:"LOCAL Nmap SYN Scan
Detected"; flags:S; threshold:type threshold, track by_src, count 20,
seconds 2; sid:1000001; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET any (msg:"LOCAL Full Port Scan
Detected"; flags:S; threshold:type threshold, track by_src, count 100,
seconds 5; sid:1000002; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET any (msg:"LOCAL Nmap XMAS Scan";
flags:FPU; sid:1000003; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET any (msg:"LOCAL Nmap NULL Scan";
flags:0; sid:1000004; rev:1;)

alert icmp $HOME_NET any -> $HOME_NET any (msg:"LOCAL ICMP Ping
Detected"; itype:8; sid:1000005; rev:1;)
```

6.3 SMB / NetBIOS / RPC Rules

```
alert tcp $HOME_NET any -> $HOME_NET 445 (msg:"LOCAL SMB Enumeration
Burst"; flags:S; flow:to_server; threshold:type threshold,
track by_src, count 5, seconds 3; sid:1000010; rev:2;)

alert tcp $HOME_NET any -> 192.168.18.105 445 (msg:"LOCAL SMB Access
Attempt to IBK170"; sid:1000011; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET 445 (msg:"LOCAL SMB Brute Force
Attempt"; flags:S; flow:to_server; threshold:type threshold,
track by_src, count 10, seconds 5; sid:1000012; rev:2;)

alert tcp $HOME_NET any -> $HOME_NET 139 (msg:"LOCAL NetBIOS Session
Attempt"; sid:1000013; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET 135 (msg:"LOCAL MSRPC Access
Attempt"; sid:1000014; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET 49152:65535 (msg:"LOCAL Dynamic
RPC Port Access"; sid:1000020; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET 5040 (msg:"LOCAL Suspicious Port
5040 Access"; sid:1000021; rev:1;)
```

6.4 LLMNR / NBT-NS Poisoning Detection (Responder)

```
alert udp $HOME_NET any -> 224.0.0.252 5355 (msg:"LOCAL LLMNR Query
Detected - Possible Responder Target"; sid:1000030; rev:1;)

alert udp $HOME_NET any -> $HOME_NET 137 (msg:"LOCAL NBT-NS Query -
Possible Responder Target"; sid:1000031; rev:1;)

alert udp $HOME_NET any -> $HOME_NET 5355 (msg:"LOCAL Possible LLMNR
Poisoning Response"; sid:1000032; rev:1;)
```

6.5 Credential Attack Rules

```
alert tcp $HOME_NET any -> $HOME_NET 445 (msg:"LOCAL Possible NTLM
Auth Attempt"; content:"|4e 54 4c 4d 53 53 50|"; sid:1000040; rev:1;)

alert tcp $HOME_NET any -> $HOME_NET 445 (msg:"LOCAL SMB Auth Burst -
Possible Brute Force"; threshold:type threshold, track by_src,
count 5, seconds 10; sid:1000041; rev:1;)
```

6.6 C2 / Reverse Shell and Exfiltration Rules

```
alert tcp $HOME_NET any -> $HOME_NET 4444 (msg:"LOCAL Possible
Metasploit Reverse Shell Port 4444"; sid:1000050; rev:1;)
alert tcp $HOME_NET any -> $HOME_NET 1234 (msg:"LOCAL Possible Reverse
Shell Port 1234"; sid:1000051; rev:1;)
alert tcp $HOME_NET any -> $HOME_NET 9001 (msg:"LOCAL Possible Reverse
Shell Port 9001"; sid:1000052; rev:1;)
alert tcp $HOME_NET any -> $HOME_NET any (msg:"LOCAL Possible Netcat
Shell"; content:"cmd.exe"; sid:1000053; rev:1;)

alert tcp $HOME_NET any -> !$HOME_NET any (msg:"LOCAL Large Outbound
Transfer - Possible Exfil"; dsize:>10000; threshold:type threshold,
track by_src, count 5, seconds 10; sid:1000060; rev:1;)

alert udp $HOME_NET any -> any 53 (msg:"LOCAL Long DNS Query -
Possible DNS Exfil"; dsize:>100; sid:1000061; rev:1;)
```

6.7 Rule Deployment

```
sudo suricata -T -c /etc/suricata/suricata.yaml -v # validate
sudo kill -USR2 $(pidof suricata) # hot-reload rules
sudo tail -f /var/log/suricata/fast.log | grep LOCAL # confirm firing
```


7. Findings and Target Hardening Summary

Attack Vector	Result	Reason
EternalBlue (MS17-010)	Not viable	SMBv1 disabled on target
NTLM Relay	Not viable	SMB signing enabled
RDP brute force	Not viable	Port 3389 closed
Anonymous SMB enumeration	Blocked	Null sessions rejected
SMB credential brute force	Throttled	Windows connection rate-limiting
Web application attacks	Not applicable	No web service running
LLMNR/NBT-NS poisoning (Responder)	Potentially viable	Broadcast protocols still enabled by default

The target Windows 11 host demonstrated strong baseline hardening against the most common SMB-based exploitation paths. The most realistic remaining attack surface identified was broadcast name-resolution poisoning (LLMNR/NBT-NS) via tools such as Responder, which does not depend on any open port and instead abuses default Windows name-resolution fallback behavior.

8. Reflection

This lab provided hands-on experience deploying and operating Suricata as a network-based intrusion detection system in a realistic two-host environment. Configuring the af-packet capture interface and HOME_NET variable correctly was essential to ensuring alerts reflected true internal/external traffic classification, and the two configuration warnings encountered (rule file path resolution and SYN-flag directional ambiguity) reinforced the importance of validating configuration with the -T test flag before deployment rather than assuming default behavior.

Running real reconnaissance tools — nmap, enum4linux, crackmapexec, nikto, and dirb — against a live target while watching Suricata's fast.log in real time made clear how signature-based and protocol-anomaly detection complement each other: the SMB malformed dialect rule caught enumeration tooling that no traditional signature would necessarily flag, simply because the tools generated protocol-non-conformant packets during their probing. Writing custom local rules afterward, tailored to the specific ports and behaviors observed during testing, demonstrated how a NIDS rule set evolves iteratively based on what an analyst actually sees on their network rather than relying solely on third-party threat intelligence feeds.

Overall, the exercise strengthened my understanding of how network-based and host-based intrusion detection serve complementary roles: Suricata identified the network-layer reconnaissance phase of an attack, while the target's own hardening (SMB signing, disabled SMBv1, closed RDP, connection throttling) determined how far that reconnaissance could realistically translate into compromise.